

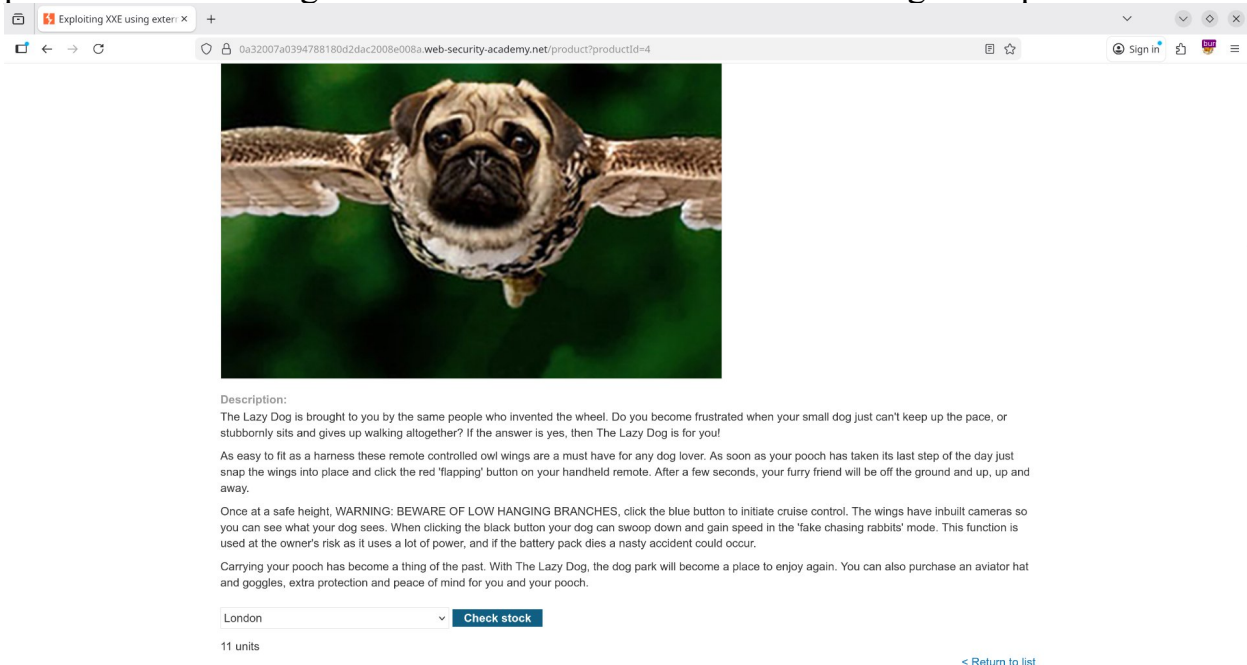
XML external entity (XXE) injection

Exploiting XXE using external entities to retrieve files

Tujuan lab : Memaksa aplikasi untuk mem-parsing entitas eksternal XML sehingga kamu bisa membaca isi file `/etc/passwd` dari server dan membuktikan bahwa kerentanan XXE-nya dapat disalahgunakan untuk mengakses file sistem.

Langkah penyelesaian :

Langkah pertama adalah pilih salah satu lalu klik view details dan pilih london paris atau sembarang kemudian klik cek stok bersamaan dengan burpsuite



The screenshot shows a web browser window with the address bar displaying a URL from `web-security-academy.net`. The page content features a pug dog wearing large, brown owl wings, set against a green background. Below the image, there is a description of 'The Lazy Dog' product, which is a remote-controlled owl harness for dogs. The text describes the product's features, including a handheld remote and a 'flapping' button. A warning is also present, advising users to be cautious of low-hanging branches. At the bottom of the page, there is a dropdown menu showing 'London' and a 'Check stock' button. The stock status is indicated as '11 units'. A link to '< Return to list' is also visible.

Exploiting XXE using exteri: x

0a32007a0394788180d2dac2008e008a.web-security-academy.net/product?productId=4

Sign in



Description:

The Lazy Dog is brought to you by the same people who invented the wheel. Do you become frustrated when your small dog just can't keep up the pace, or stubbornly sits and gives up walking altogether? If the answer is yes, then The Lazy Dog is for you!

As easy to fit as a harness these remote controlled owl wings are a must have for any dog lover. As soon as your pooch has taken its last step of the day just snap the wings into place and click the red 'flapping' button on your handheld remote. After a few seconds, your furry friend will be off the ground and up, up and away.

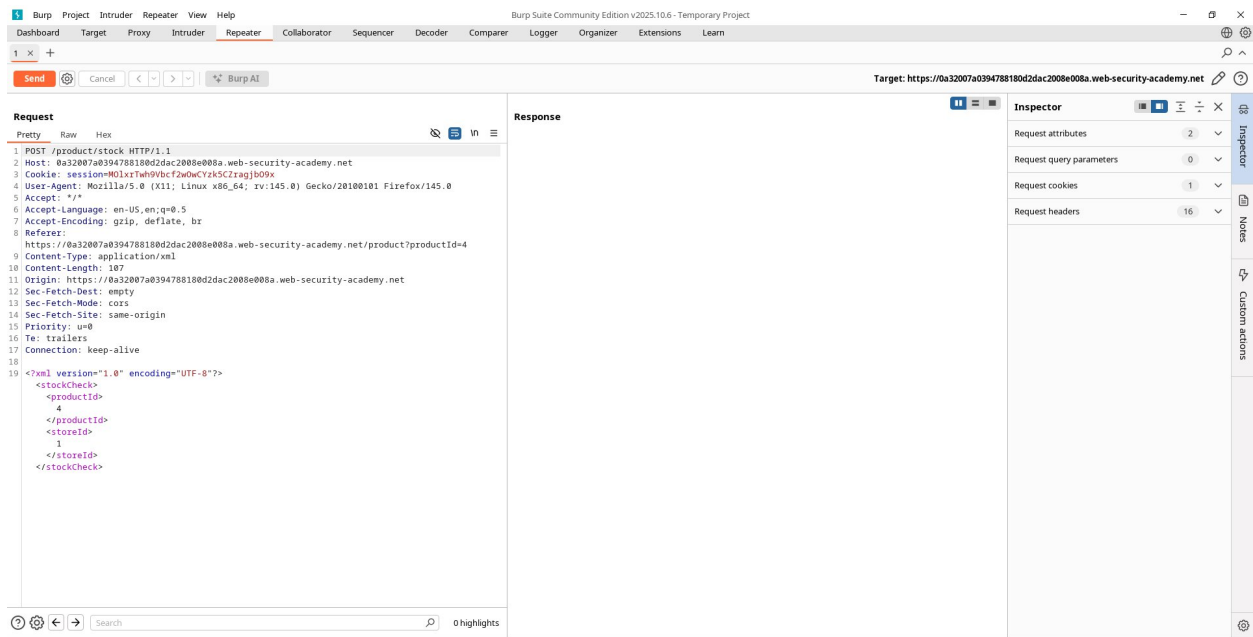
Once at a safe height, WARNING: BEWARE OF LOW HANGING BRANCHES, click the blue button to initiate cruise control. The wings have inbuilt cameras so you can see what your dog sees. When clicking the black button your dog can swoop down and gain speed in the 'fake chasing rabbits' mode. This function is used at the owner's risk as it uses a lot of power, and if the battery pack dies a nasty accident could occur.

Carrying your pooch has become a thing of the past. With The Lazy Dog, the dog park will become a place to enjoy again. You can also purchase an aviator hat and goggles, extra protection and peace of mind for you and your pooch.

London

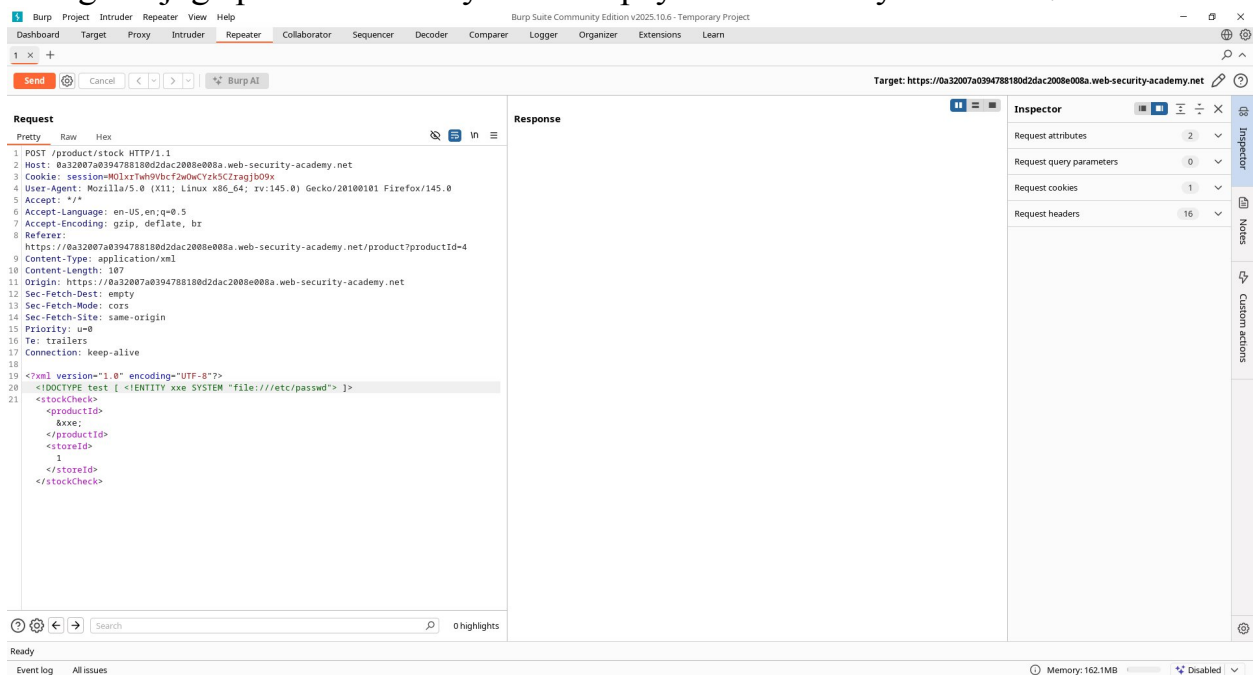
11 units

< Return to list



Lalu kemudian masukan payload `<!DOCTYPE test [ <!ENTITY xxe SYSTEM "file:///etc/passwd"> ]>`

Dan ganti juga product id menyesuaikan payload tersebut yaitu `&xxe;`



Kemudian klik send dan lihat

The screenshot shows the Burp Suite interface with the 'Repeater' tab selected. A POST request is being prepared to the target `https://0a32007a0394788180d2dac2008e008a.web-security-academy.net`. The request body is an XML payload for a stock check. The 'Send' button is highlighted. The 'Response' tab shows a 400 Bad Request status. The 'Inspector' tab on the right shows the request details.

Lalu klik kanan dan pilih request in browser kemudian in original session dan copy lalu buka di browser

The dialog box titled 'Repeat request in browser' contains the following text:

To repeat this request in your browser, copy the URL below and paste into a browser that is configured to use Burp as its proxy.

The URL provided is: `http://burpsuite/repeat/1/clen66ydaxsremhwdjuqhwwhdpyp1b0v`

There is a checkbox labeled 'In future, just copy the URL and don't show this dialog'.

Buttons for 'Copy' and 'Close' are present.

